

Awareness: Build a collaborative culture

Awareness is the key problem in the vast landscape of security. The best way to create awareness is build communities and make people talk about the importance of security. A few simple steps can be followed to achieve this:

- Brainstorm with your security community and experts
- Identify short-term and long-term goals
- Build security champions at global and regional levels, and in the office and team to achieve these goals
- Conduct regular knowledge-sharing sessions
- Measure improvements across teams and projects regularly
- Retrospect and repeat

Integrate: Security in the development process

Developers need to think about security during the project development life cycle itself. The first step towards achieving this is to have threat modelling, which is thinking about what can go wrong before it goes wrong so that something can be done to prevent it. 'A Guide to Threat Modelling for Developers' by Jim Gumbley is an awesome article on this subject.

Security plugins in IDEs can provide feedback while coding. There are several plugins available to identify vulnerable dependencies/

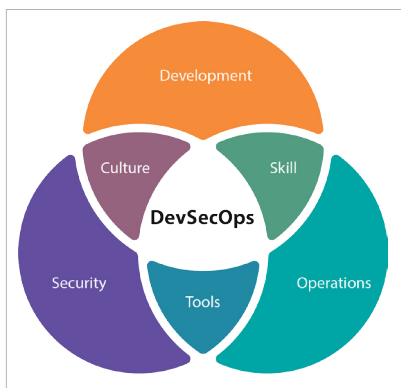


Figure 4: DevSecOps



Figure 2: Agile life cycle with security

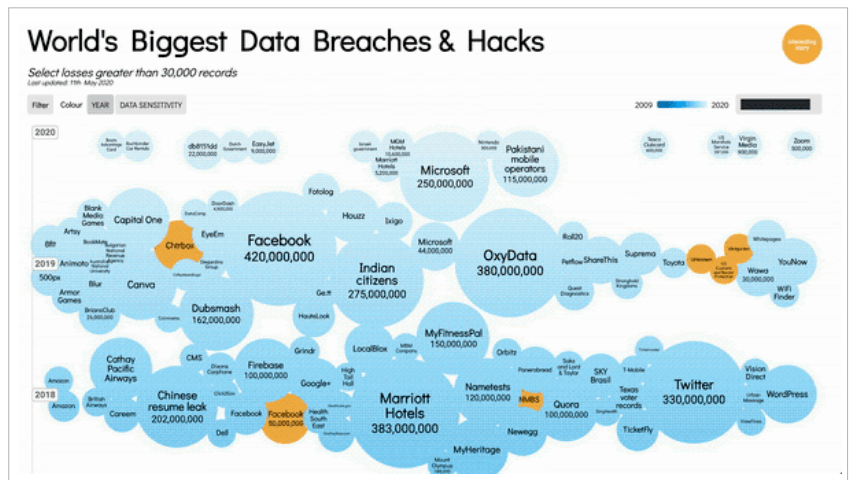


Figure 3: Security breaches

libraries, static code analysis, or even for scanning containers.

There are two ways of detecting vulnerabilities in OSS packages:

- Detect vulnerabilities when you add any dependencies/libraries
- Scan the whole code base in the background whenever the OSS list is updated

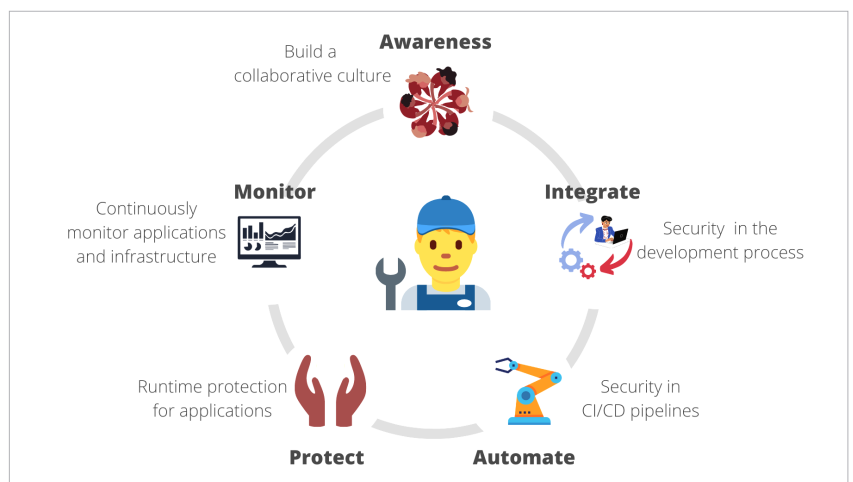


Figure 5: DevSecOps—goals